

ACTIVITY PACK

Activity 1: Scenario

Activity 1 - Threat Modelling a Generative AI Concierge

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	2.1 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Scenario

Activity 1 - Scenario

Threat Modelling a Generative AI Concierge

Course: AI Security for Autonomous AI Agents (TGS-2025060473) **Duration:** 45 minutes | **Format:** Small groups of 3 - 4 | **Type:** Real-world case study

The organisation

Marina Crescent Hotel is a 340-room business hotel on Singapore's waterfront, part of a regional group with properties in Kuala Lumpur, Bangkok and Jakarta. Occupancy runs at 82%, and roughly 60% of guests are corporate travellers on negotiated rates.

The hotel's guest satisfaction scores have slipped for three consecutive quarters. Exit surveys point at one cause: the front desk is overwhelmed between 3pm and 7pm, and guests wait an average of eleven minutes for simple requests.

The deployment

Six weeks ago, the group's digital team launched "**Cres**" - a generative AI concierge - without consulting the group security function. Cres is live on three channels:

- the in-room tablet,
- WhatsApp (guests message a published number), and
- the public website chat widget (no login required).

Cres is built on a commercial large language model with a retrieval layer. To answer guest questions it retrieves from four sources:

Source	Contents	Who can write to it
Property knowledge base	Facilities, opening hours, policies	Marketing team
Guest profile service	Name, loyalty tier, stay history, dietary notes, passport number (from check-in)	Property management system
Local events feed	Third-party API of Singapore events and attractions	External vendor
Guest review corpus	Scraped public reviews from travel sites, refreshed nightly	Automated scraper

Cres can also perform four actions through tool calls: **book a restaurant table**, **raise a housekeeping ticket**, **order room service to a room number**, and **email a folio (bill) copy to a guest's registered address**.

What the digital team believes

The project lead has told the executive committee:

"Cres is safe. It only sees hotel data, it has a system prompt that tells it never to reveal personal information, and we tested it with over two hundred guest questions before launch. It has no access to payment card data, so PDPA is not really in scope for us."

Early signals

Three things have happened that nobody has yet connected:

1. A guest posted a screenshot on social media showing Cres greeting them with ****another guest's name and loyalty tier****. The digital team closed the ticket as "a caching glitch."
2. The events vendor was acquired last month. Their API now returns a longer description

field for each event; nobody reviewed the change.

3. Room service received an order for a room that was **unoccupied**, charged to a guest who had already checked out. Finance wrote it off as a \$46 error.

Your role

You are the newly appointed **AI security working group**. The executive committee has asked you to produce a threat model for Cres before the group rolls it out to the other three properties next quarter. The committee is not technical; they respond to risk, cost and reputation.

You have this scenario, and nothing else. Work from what the architecture tells you.